

Information Security Policy

Audience: public. This document describes our security commitments in general terms. It intentionally omits implementation details, cryptographic specifics, and internal procedures.

Version 1.0 · Last reviewed 2026-05-29 · Next review by 2027-05-29

Purpose

This policy states how we protect the information entrusted to us and the systems that process it. It sets the principles that guide every security decision across the platform and reflects our commitment to handling data responsibly.

Scope

This policy applies to the services we operate, the data they process, and the people who build and run them. Related controls for who may access systems and data are described in the companion Access Control Policy.

Our principles

- **Confidentiality, integrity, and availability.** We protect information from unauthorized access, guard against unauthorized or accidental change, and keep our services reliably available to the people who depend on them.
- **Secure by default.** Systems start in their most protective state. Access and capabilities are granted deliberately, never assumed.
- **Defense in depth.** We layer independent safeguards so that no single failure exposes sensitive information.
- **Least privilege.** People and systems receive only the access they need, for only as long as they need it.
- **Modern identity.** We are reducing reliance on shared secrets such as passwords in favor of stronger, phishing-resistant ways to establish identity, and we are implementing federated, standards-based sign-in through trusted identity providers.
- **Continuous improvement.** We review our posture regularly and strengthen it as threats and best practices evolve.

Data protection

We encrypt sensitive data both in transit and at rest using strong, industry-standard methods. Connections between our services are authenticated and encrypted. Sensitive material is isolated from the systems that use it, and we minimize the data we collect and retain to what is necessary for the service to function.

Key and secret management

Cryptographic keys and other secrets are managed within a dedicated, isolated service with a defined lifecycle, including controlled creation, rotation, and retirement. Secrets are not exposed to the systems that consume cryptographic operations, and access to key material is tightly restricted and monitored.

Logging, monitoring, and auditing

We maintain tamper-evident records of security-relevant operations. These records support monitoring, investigation, and accountability, and are retained in line with applicable regulatory and contractual requirements.

Resilience and availability

We design our services to remain available and to recover from disruption. Critical data is backed up, and recovery procedures are maintained and exercised.

Secure development and vulnerability management

Security is part of how we build and operate software. We review changes, test our defenses, and track and remediate vulnerabilities on a risk-prioritized basis.

Incident response

We maintain a process to detect, contain, investigate, and recover from security incidents. Where we have a legal or contractual obligation to notify affected parties, we do so promptly.

Standards alignment

Our security program is designed to align with widely recognized industry frameworks for information security and cryptographic assurance. We pursue alignment as an ongoing commitment rather than a one-time achievement.

Where we federate identity or delegate access between parties, we favor open, widely adopted standards — including OAuth 2.0 for delegated authorization — over proprietary mechanisms.

Responsible disclosure

We welcome reports of suspected security issues. If you believe you have found a vulnerability, please contact us at [**industry@barcher.dev**](mailto:industry@barcher.dev). We ask that you give us a reasonable opportunity to investigate and remediate before any public disclosure, and we commit to handling reports in good faith.

Governance

This policy is owned by the security function and reviewed at least annually, or sooner in response to material changes in our services, threats, or obligations.